

Data Retention and Disposal Policy

Field	Value
Document ID	SEC-POL-003
Version	1.0
Effective	June 6, 2026
Owner	Eric Franco, CEO
Next Review	June 6, 2027
Status	Active

1. Purpose and Scope

This Data Retention and Disposal Policy establishes how long Naviio, Inc. ("Naviio") retains data collected through its financial intelligence platform, and how that data is securely disposed of when retention periods expire or when customers request deletion.

This policy applies to all data processed by Naviio, including:

- Consumer financial data received via Plaid (bank transactions, account balances)
- Accounting data received via QuickBooks, Xero, and similar integrations
- Revenue and subscription data received via Stripe
- Payroll data received via Gusto or ADP
- User account and authentication data
- Application and system logs
- Generated reports and derived analytics

This policy is reviewed annually and updated to reflect changes in applicable data privacy laws, including the California Consumer Privacy Act (CCPA), the Gramm-Leach-Bliley Act (GLBA), and other applicable regulations.

2. Governing Principles

- **Minimum necessary retention:** Data is retained only for as long as it serves the business or legal purpose for which it was collected.
 - **Defined periods:** Every data category has an explicit retention period, not an open-ended "retain indefinitely" policy.
 - **Automated enforcement:** Retention limits are enforced by automated nightly purge jobs, not manual processes.
 - **Secure disposal:** Data is permanently deleted in a manner that makes recovery infeasible. There is no archiving of customer data beyond documented retention windows without explicit consent.
 - **User rights:** Customers may request deletion of their data at any time. Naviio honors deletion requests within the timeframes defined in Section 5.
-

3. Retention Schedule

3.1 Customer Financial Data

Data Category	Source	Retention Period	Justification
Bank transaction records	Plaid	25 months from collection date	Enables 2-year trend analysis; aligns with standard financial reporting periods
Account balance snapshots	Plaid	25 months	Historical comparison for dashboard and forecasting features
Profit & Loss data	QuickBooks / Xero	25 months	Financial planning and year-over-year reporting
Balance sheet data	QuickBooks / Xero	25 months	Historical financial analysis
Expense records	QuickBooks / Xero	25 months	Expense trend analysis
Revenue metrics (MRR, ARR, churn)	Stripe	25 months	Subscription trend analysis
Payroll totals	Gusto / ADP	25 months	Burn rate and expense reporting
Generated report PDFs	S3	Until deletion request	Customer-controlled; deleted on account deletion

3.2 Account and Authentication Data

Data Category	Retention Period	Justification
User account records (email, name, hashed password)	Duration of account + 30 days post-deletion	Needed while account is active; grace period for recovery
OAuth access tokens and refresh tokens	Duration of active integration connection	Revoked immediately on disconnect or account deletion
Session tokens	7 days (rolling expiry)	Short-lived by design; no persistent storage beyond expiry
MFA secrets	Duration of account with MFA enabled	Deleted when MFA is disabled or account is deleted

3.3 Logs and Operational Data

Data Category	Retention Period	Justification
Application authentication logs (login, logout, failed attempts)	90 days	Security monitoring and incident response
Application error logs	90 days	Debugging and operational support

AWS CloudTrail logs (infrastructure access)	1 year	Security audit trail; AWS best practice
RDS audit logs (database access)	90 days	Access monitoring and incident investigation
CloudFront / WAF access logs	90 days	Security analysis

3.4 Backup Data

Data Category	Retention Period	Notes
RDS automated snapshots	7 days (rolling)	Encrypted; automatically overwritten after 7 days
Manual snapshots (taken before migrations)	Deleted within 30 days of creation	Manually reviewed and removed

3.5 Business Records (Non-Customer Data)

Data Category	Retention Period	Justification
Contracts and agreements	7 years post-termination	Legal and regulatory requirement
Financial records (invoices, payments)	7 years	Tax and accounting requirements
Security incident logs	3 years	Regulatory and insurance requirements
Employee and contractor records	Duration of engagement + 3 years	Employment law requirements

4. Automated Retention Enforcement

Naviio enforces data retention through automated processes to prevent human error and ensure consistent application of this policy:

- **Nightly purge jobs** scan the primary database for records past their retention period and permanently delete them.
- **Purge events are logged** — each automated deletion run records: timestamp, data category, record count deleted, and any errors.
- **S3 lifecycle policies** are configured to automatically delete report objects after applicable periods.
- **RDS backup retention** is set to 7 days at the infrastructure level, enforced by AWS automatically.
- **Application session expiry** is enforced by the JWT `exp` claim; expired tokens are rejected server-side regardless of client-side storage.

Purge job logs are retained for 90 days and reviewed quarterly to confirm correct operation.

5. Data Deletion — Customer Rights

Customers have the right to request deletion of their data at any time. Naviio honors all deletion requests promptly.

5.1 How to Request Deletion

Customers may request deletion by:

- Using the account deletion feature within the Naviio application (Settings → Account → Delete Account)
- Submitting a written request to francoeric34@gmail.com with subject line: **Data Deletion Request**

5.2 Deletion Timeline

Action	Timeframe
Acknowledge receipt of deletion request	Within 24 hours
Revoke all OAuth tokens (Plaid, Stripe, QuickBooks, etc.) via provider APIs	Within 24 hours
Invalidate all active user sessions	Within 24 hours
Flag account as deleted; disable all access	Within 24 hours
Permanently delete all financial data, account records, and report PDFs	Within 30 days
Confirm deletion to customer via email	Within 30 days
Data removed from backup snapshots	Within 90 days (as backups rotate)

5.3 What Is Deleted

Upon a confirmed deletion request, Naviio permanently deletes:

- All financial data associated with the account (transactions, balances, accounting records, revenue metrics, payroll data)
- User account record (email, name, hashed password, MFA secret)
- All OAuth tokens and API keys for connected integrations
- All generated report PDFs stored in S3
- All cached data associated with the account
- All active session tokens

5.4 What Is Retained After Deletion

The following may be retained after deletion for legal or operational reasons:

- **Anonymized aggregate data** that cannot be re-linked to the individual account (e.g., platform-level usage statistics with no identifying information)
- **Security incident logs** that reference the account, retained for the 3-year security log period, accessible only to the CEO and legal counsel
- **Billing records** (invoice amount, payment date — no financial account details) retained for 7 years per accounting requirements

Naviio does not retain any consumer financial data (transactions, balances, account details) after the deletion process is complete.

6. Secure Disposal Methods

Data Type	Disposal Method
Database records (RDS PostgreSQL)	Hard DELETE SQL operations; PostgreSQL does not retain deleted rows after VACUUM. AWS RDS storage is encrypted; decommissioned storage is destroyed by AWS per their media destruction policy.
S3 objects (report PDFs)	DeleteObject API call; S3 versioning purge applied to all versions.
RDS snapshots	AWS DeleteDBSnapshot API; storage is securely destroyed by AWS.
ElastiCache (Redis)	TTL expiry or explicit DEL command; Redis evicts data from encrypted, ephemeral memory.
Application logs	CloudWatch log stream deletion; AWS retains no copies after the configured retention period.
OAuth tokens (third-party)	Revoked via provider API (/item/remove for Plaid, deauthorization for Stripe, etc.) before local deletion.
Employee device data	Full-disk encryption (FileVault / BitLocker) is required on all devices. Upon departure, devices are remotely wiped via MDM before reuse or disposal.

7. Plaid-Specific Retention Obligations

Naviio's retention of Plaid-sourced data is governed by Plaid's Developer Policy in addition to this policy. Specific commitments:

- Plaid-sourced data (transactions, balances, account information) is retained for no longer than **25 months** or until the customer deletes their account, whichever comes first.
 - Plaid access tokens are revoked via `/item/remove` immediately upon customer-initiated disconnection or account deletion — we do not retain tokens for disconnected items.
 - Plaid data is not retained in backup snapshots beyond the 7-day rolling backup window after account deletion.
 - Naviio does not use retained Plaid data for any purpose other than providing the financial intelligence service to the authenticated account holder.
-

8. Policy Compliance and Review

- This policy is reviewed **annually** (or following any significant change to data processing activities, regulatory requirements, or a material security incident).
 - Compliance with retention schedules is verified quarterly by reviewing purge job logs and confirming automated enforcement is functioning correctly.
 - Exceptions to this policy (e.g., legal hold on specific data beyond normal retention) require written CEO approval, documentation of the legal basis, and a defined end date.
-

9. Related Documents

- [Information Security Policy](#) — SEC-POL-001
- [Access Controls Policy](#) — SEC-POL-002
- [Data Handling Procedures](#) — SEC-PROC-001
- [Incident Response Plan](#) — SEC-IRP-001